Proof of Concept (POC): Zoho MCP Security Assessment, Access Revocation & Centralized Governance

Prepared For: Client Necrop
Subject: Restricting & Controlling Zoho Books Access via Zoho Model Context Protocol (MCP) with External AI Tools (Claude)
Document Type: Security Architecture POC & Technical Remediation Runbook

---

1. Executive Summary

1.1 Background & Incident Scenario

Client Necrop previously engaged an external consultant who connected Necrop's **Zoho Books** environment to **Anthropic Claude** using **Zoho Model Context Protocol (MCP)** via his personal email account. Following the consultant's departure, Necrop disabled his user profile within Zoho. However, leadership identified two critical security concerns:

1. Whether disabling the user profile alone is sufficient to sever active MCP connections and OAuth tokens.
2. Whether sensitive financial data retrieved during the consultant's tenure remains accessible inside his personal Claude account.

1.2 Purpose of This POC

This Proof of Concept (POC) evaluates the technical mechanics of Zoho MCP authentication, provides an **immediate step-by-step remediation runbook** to permanently sever all live data pathways to Necrop's Zoho Books instance, and establishes a **Centralized MCP Governance Framework** so the organization retains 100% control over employee and contractor AI integrations moving forward.

---

2. Technical Architecture: How Zoho MCP & Claude Interact

To understand the security boundary, it is essential to distinguish between **Live API Execution** (controlled by Zoho) and **Historical Context Storage** (controlled by the AI Client, Claude).

```
None
+-------------------------------------------------------------------------+
|                        EXTERNAL CONSULTANT                              |
|  [ Personal Claude Account ]  <--- (Stores Historical Chat Responses)   |
+---------------+---------------------------------------------------------+
                |
                | 1. Prompts AI / Calls MCP Tool (HTTPS / SSE)
                v
+-------------------------------------------------------------------------+
|                        ZOHO MCP SERVER LAYER                            |
|  - Hosted at mcp.zoho.com                                               |
|  - Authenticates via:                                                   |
|      A) Authorization on Demand (User-specific OAuth Token)             |
|      B) Authorization via Connections (Shared Org/Admin OAuth Token)    |
+---------------+---------------------------------------------------------+
                |
                | 2. Executes API Call via OAuth 2.0 Scope
                v
+-------------------------------------------------------------------------+
|                     NECROP ZOHO BOOKS ENVIRONMENT                       |
|  - Invoices, Contacts, Ledgers, Financial Reports                       |
+-------------------------------------------------------------------------+
```

---

3. POC Investigation Findings (Answers to Key Objectives)

Objective 1: How to revoke existing MCP connections, access tokens, and permissions when an employee or consultant leaves

Revoking access requires a **four-layer termination process**:

1. Deleting or disabling the specific MCP Server endpoint in the **Zoho MCP Console**.
2. Revoking shared **Deluge / Developer Space Connections** in Zoho Books.
3. Invalidating active **OAuth 2.0 Refresh and Access Tokens** in Zoho Accounts / Zoho Directory.
4. Deleting the user profile or stripping role permissions within **Zoho Books**.

Objective 2: Is disabling a user's Zoho account sufficient to terminate access through an existing MCP connection?

No, disabling the user account alone is NOT guaranteed to terminate access. It depends on how the consultant existed in Zoho and how the MCP server was configured:

- **Risk Scenario A — Shared / Admin Connections ("Authorization via Connections"):** Zoho MCP allows servers to authenticate using a pre-configured Zoho

Connection (often authorized by a Super Admin or shared service account). If the consultant configured the MCP server using an Admin's connection or an organization-level API token, deactivating the consultant's individual Zoho Books profile **will not stop the MCP link from pulling live Zoho Books data**.

- **Risk Scenario B — External Personal Email Invite ("Authorization on Demand"):** Because the consultant used a *personal email address*, Necrop could only deactivate his *membership* inside Necrop's Zoho Books organization—not his actual personal Zoho account (`accounts.zoho.com`). While deactivating his Zoho Books user blocks user-level API calls (`Authorization on Demand`), any lingering OAuth connections or shared webhooks created under organization settings remain active until explicitly revoked.

Objective 3: How to prevent sensitive Zoho data from being retained or accessed through personal AI accounts after access is revoked

- **What Technical Revocation Achieves:** Revoking Zoho MCP tokens immediately blocks the consultant from querying **new or live** data from Zoho Books. Any attempt in Claude to run a Zoho Books tool will fail with an authentication error.
- **What Technical Revocation Cannot Do (Residual Risk):** Zoho MCP transmits financial records (invoices, customer balances, P&L figures) as plain text into Claude's conversation window. Once that text is displayed in the consultant's **personal Claude account**, it is stored in Anthropic's cloud under his personal chat history. Revoking Zoho access **cannot remotely delete his past Claude chats**.
- **Required Action for Past Data:** Because the account is owned personally by the consultant, Necrop must require the consultant to sign a **Data Destruction & Offboarding Attestation**, confirming he has permanently deleted all Claude chat threads and Projects containing Necrop data.
- **Future Prevention:** Mandate corporate-owned **Claude for Team / Enterprise** accounts integrated with corporate Single Sign-On (SSO) so IT can immediately lock users out of historical AI chats upon offboarding.

Objective 4: Security policies and technical controls to prevent recurrence

To prevent unauthorized or lingering AI integrations in the future, Necrop must implement:

1. **Zero Personal Email Policy:** Never invite contractors via `@gmail.com` or personal emails. Issue a temporary `@necrop.com` identity managed under Zoho Directory.
2. **Centralized Admin-Only MCP Creation:** Restrict standard users from creating Zoho MCP servers or authorizing third-party OAuth apps.
3. **Read-Only Service Roles for AI:** Restrict MCP tool scopes to read-only actions (blocking `delete` or `update` operations on financial records).
4. **IP Whitelisting:** Restrict Zoho Books API and MCP calls to corporate VPN IP ranges.

Objective 5: Administrative controls provided by Zoho to monitor, restrict, or manage MCP connections

Zoho provides four native administrative control planes:

- **Zoho MCP Console (`mcp.zoho.com`):** Central dashboard to view, disable, delete, and scope tools for all MCP servers.
- **Zoho Books Developer Space:** Manages shared OAuth Connections, API usage limits, and webhooks.
- **Zoho Directory / Admin Console (`admin.zoho.com`):** Enforces SSO, IP restrictions, OAuth app whitelisting, and forced session/token revocation across managed accounts.
- **Zoho Books Activity Logs & Audit Trail:** Tracks every record viewed, created, or modified via API or user session.

---

4. Exact Step-by-Step Guide: Revoking the Consultant's Zoho Books MCP Access

Perform the following 5 steps in exact sequence using a **Zoho Super Administrator** account to completely sever the consultant's access.

Step 1: Disable & Delete the MCP Server in Zoho MCP Console

This immediately breaks the URL endpoint connected to the consultant's Claude desktop or web client.

1. Log in to the **Zoho MCP Console** (`https://mcp.zoho.com` — or your regional domain such as `.in` or `.eu`) using the Super Admin account.
2. Navigate to the **MCP Servers** tab on the left navigation menu.
3. Locate any MCP Server referencing **Zoho Books** or created during the consultant's engagement.
4. Click the **Settings / More Options (`...`)** icon next to the server:
    - Review the **Tools** and **Connections** tab to note which Zoho account authorized it.
    - Click **Disable** to immediately halt traffic, then select **Delete** to permanently destroy the server endpoint.

Step 2: Revoke Shared OAuth Connections in Zoho Books

If the consultant used *Authorization via Connections*, this step invalidates the underlying token bridging Zoho Books and MCP.

1. Log in to **Zoho Books** (`https://books.zoho.com`) as the Admin.
2. Click the **Gear Icon (Settings)** in the top right corner.
3. Navigate to **Developer Space** -> **Connections** (located near the bottom of the Settings menu).
4. Inspect both **My Connections** and **Shared Connections**.
5. Identify any connection linked to **Zoho OAuth / Zoho Books** (or named after Claude / MCP / the consultant).
6. Hover over the connection and click **Revoke** or **Delete**.

Step 3: Revoke Active OAuth Refresh Tokens in Zoho Accounts

If an internal Admin account was used to authorize the consultant's MCP setup, or if you have access to the account that authorized the token, revoke the OAuth grant directly.

1. Log in to **Zoho Accounts** (`https://accounts.zoho.com`).
2. In the left sidebar, click **Security** -> **Connected Apps** (and also inspect **Active Authtokens** / **App Passwords**).
3. Look for entries labeled **Zoho MCP**, **Claude**, or any unrecognized OAuth client created during the consultant's tenure.
4. Click on the application entry and select **Revoke Access** (Trash icon).
5. *(If the consultant also had an account under Zoho Admin Console `https://admin.zoho.com`)*: Go to **Users** -> select the user -> **Security** -> **Connected Apps** and revoke all active sessions and tokens.

Step 4: Permanently Remove User & Role Permissions in Zoho Books

Do not leave an external personal email in a simple "Inactive" state with an Admin or Accountant role still attached.

1. In **Zoho Books**, go to **Settings** -> **Users & Roles** -> **Users**.
2. Locate the consultant's personal email profile.
3. First, click **Edit**, change their Role to a restricted custom role with **zero module permissions** (as a safeguard), and save.
4. Click the **More (`...`)** button next to the consultant's name and select **Delete** to completely purge their external email association from Necrop's Zoho Books organization.

Step 5: Audit Zoho Books Activity Logs for Data Exposure

Verify when the consultant last accessed Zoho Books and what records were pulled.

1. In **Zoho Books**, navigate to **Accountant** (or **Reports**) -> **Activity Logs / Audit Trail**.
2. Filter the logs by **User** (select the consultant's name) and **Date Range**.

3. Export the log to CSV for your compliance records to confirm no API calls have occurred after completing Steps 1–4.

---

5. Target State: Centrally Controlling MCP Access for Employees

To achieve your primary objective—**centralized company control over MCP access and permissions**—Necrop should transition to the following governance model:

Control Area	Uncontrolled Practice (Past State)	Centralized Governance Standard (Target State)
User Identity	Consultant invited via personal email (`@gmail.com`).	**Corporate Email Only:** All staff and contractors receive a managed `@necrop.com` account under **Zoho Directory**.
MCP Server Creation	Individual users create and configure their own MCP servers.	**Admin-Only Provisioning:** Only the IT Super Admin creates MCP servers in Zoho MCP Console and shares access internally.
Authentication Mode	Unmonitored OAuth tokens with full module scopes (`ZohoBooks.fullaccess.all`).	**Scoped Service Account:** Admin configures a dedicated *AI Read-Only Role* in Zoho Books and exposes only specific read tools (e.g., `list_invoices`, `get_customer_balance`).
AI Client Platform	Personal Claude accounts where chat history is owned by the individual.	**Enterprise AI Workspace:** Company-managed **Claude for Team / Enterprise** with SSO enforced; offboarding revokes access to all past chats immediately.
Network Security	MCP accessible from any public internet connection.	**IP Restrictions:** Configure Zoho Directory & Zoho Books IP restrictions so APIs only respond to authorized corporate VPN IPs.
